



Chartered Institute of
Information Security

Skills Framework

Version 4 | April 2026

[CLICK HERE TO START](#)





Contents



3.	Introduction	35.	I - Cyber and Information Security Research
4.	Framework Skill Areas	37.	J - Human Centric Security
5.	Framework Skill Levels	39-41 Professional Skill Areas	
9.	Skills Summary	39.	1 - Management, Leadership, Business and Communications
12-35	Technical Skill Areas	41.	2 - Contributions to the Cyber and Information Security Profession and Professional Development
13.	A - Cyber and Information Security Governance and Management	43.	Summary of Changes
17.	B - Threat Assessment, Information Risk Management, Intelligence and Data Analysis	44.	CII Sec Frameworks
20.	C - Implementing Secure Systems		
23.	D - Assurance: Audit, Investigation, Compliance and Testing		
26.	E - Operational Security Management		
27.	F - Incident Management, Investigation and Digital Forensics		
31.	G - Data Protection, Privacy and Identity Management		
33.	H - Business Resilience		



Introduction

The CIISec Skills Framework describes the range of competencies expected of information security, cyber, digital and information assurance professionals in the effective performance of their roles. It was developed and has been maintained through collaboration between private and public sector organisations, world-renowned academics and security leaders.

It recognises that technology is fast moving and, as a result, terminology and devices may change. This Framework will not include specific devices, software or technologies but will try to reflect wider adoption of emerging technologies at a high level e.g. vehicle telematics, building management and the internet of things.

It defines the skills and capabilities expected of security professionals in their practical application and is not just an assessment of their knowledge. It is recognised that not all roles require detailed experience in all competency areas.

Security professionals can have either a deep specific specialist knowledge and or a broad understanding of security. Many sectors have specific legislation and regulations and sometimes bespoke technologies. The Framework is agnostic to this and therefore enables individuals to map to their sector against the Skills Framework.

To demonstrate professional competence through peer assessment members are required to provide evidence against a number of Skill Areas. There are some Mandatory and Essential skills which all applicants are required to evidence. There is then a requirement to identify and evidence skills appropriate to their role or specialism. Further explanation can be found in the [CIISec Guidance for Professional Registration Membership](#).

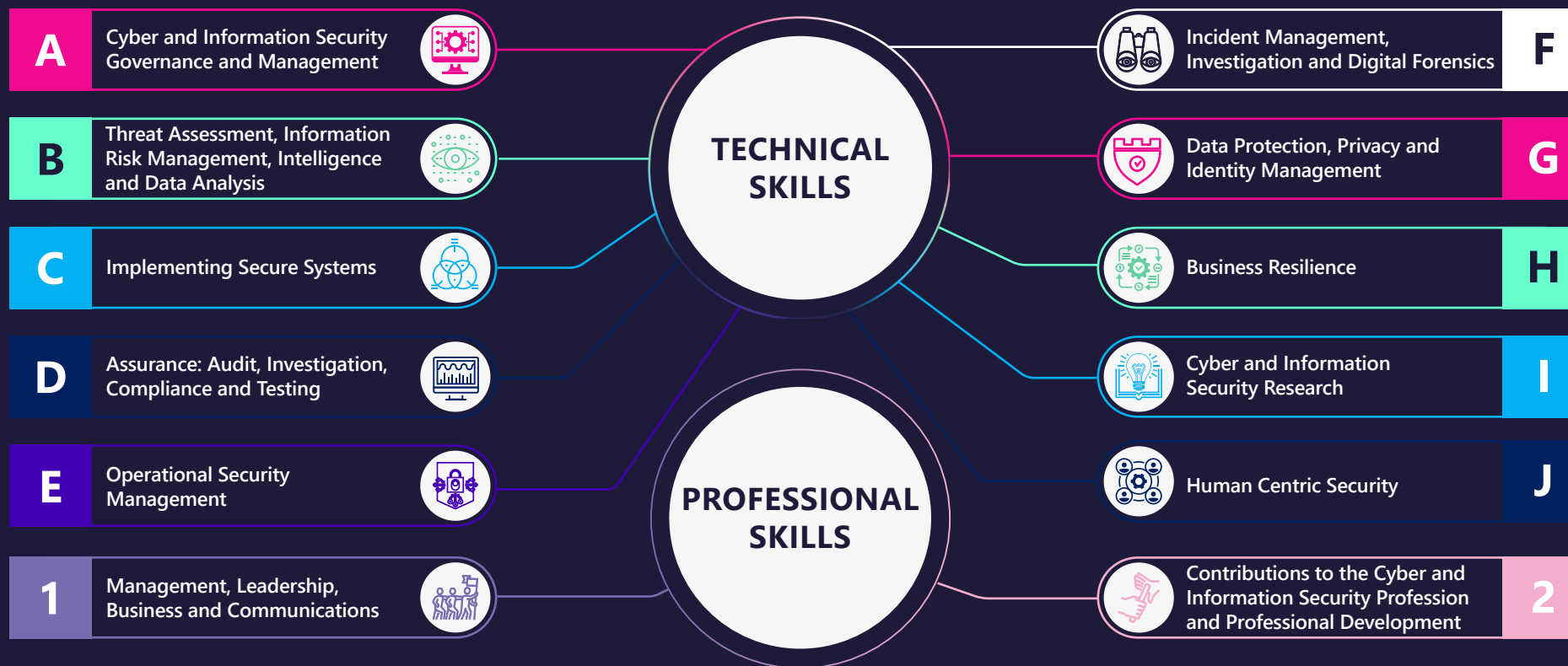
Implementing the CIISec Skills Framework doesn't need to be complex, and we can guide you through the initial steps. We also work with a preferred skills implementation partner, offering expert consultancy and intuitive software to help Corporate Members understand, develop and optimise workforce capabilities.

Please contact membership@ciisec.org if you would like an introduction.

See page 44 for a brief introduction to the other frameworks that form part of CIISec's Capability Development Methodology.



Framework Skill Areas

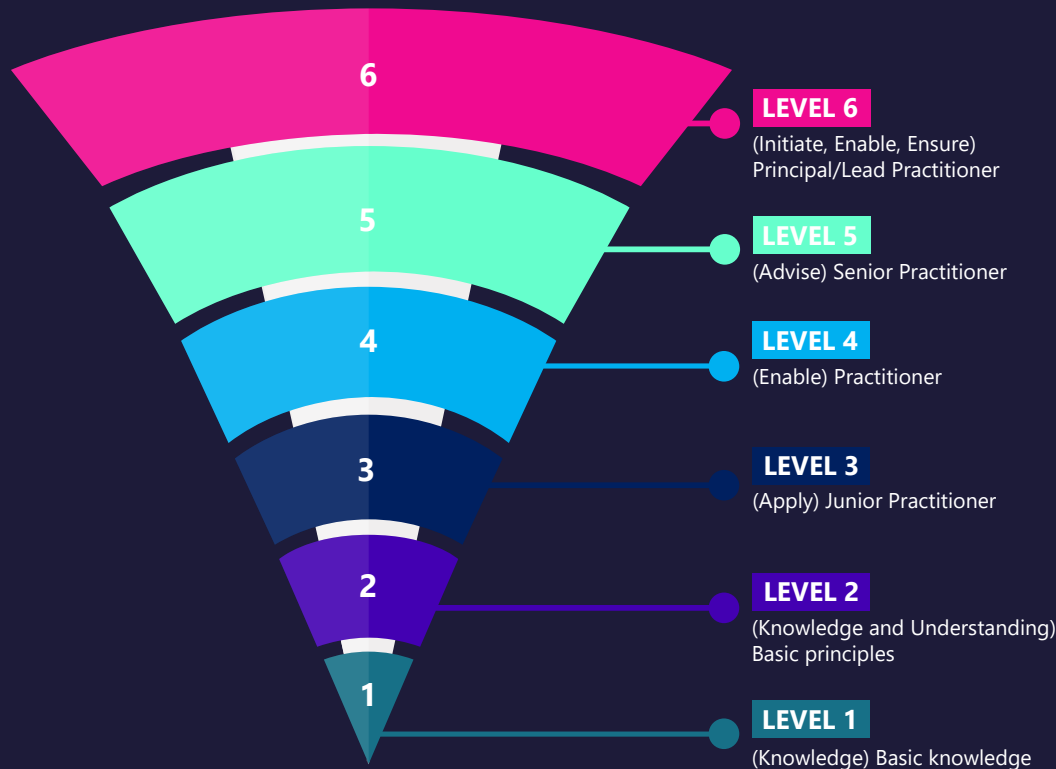


CLICK ON EACH SKILL TO VIEW MORE INFORMATION

The multi-disciplinary complexity of the cyber and information security profession joins physical and computer sciences, mathematics, economics, law and psychology. The CIISec Skills Framework defines these areas at a high level. Technical Skill Areas A to J cover the wide range of technical, operational and sector specific skills required; Professional Skill Area 1 defines the interpersonal and collegial skills needed to work effectively and Professional Skill Area 2 defines the skills required to support personal career development and take the profession forward.



Framework Skill Levels



Levels 5 and 6 are expected to operate at Senior, Principal and Lead Practitioner level, with high levels of autonomy and very little oversight from others

Levels 3 and 4 are expected to operate at Practitioner level, with a degree of experience, but will require some guidance

Levels 1 and 2 have basic knowledge and understanding but are unlikely to demonstrate experience and will require a significant amount of guidance

The CIISec Skills Framework defines a series of Skill Levels (ranging from 1-6 and aligned with each skill area) that can be used to understand different levels of competence in each particular discipline. This also provides a common scale to support assessment and benchmarking activity.



TECHNICAL SKILL AREA A – Cyber and Information Security Governance and Management	
A1 – Governance	
A2 – Policy and Standards	ESSENTIAL
A3 – Cyber and Information Security Strategy	
A4 – Innovation and Business Improvement	
A5 – Behavioural Change	
A6 – Legal and Regulatory Environment and Compliance	ESSENTIAL
A7 – Third Party Management	
TECHNICAL SKILL AREA B – Threat Assessment, Information Risk Management, Intelligence and Data Analysis	
B1 – Threat Intelligence, Assessment and Threat Modelling	
B2 – Risk Assessment	ESSENTIAL
B3 – Information Risk Management	
B4 – Cyber Digital Intelligence	
B5 – Data Analysis	
TECHNICAL SKILL AREA C – Implementing Secure Systems	
C1 – Enterprise Security Architecture	
C2 – Technical Security Architecture	
C3 – Secure Development	
TECHNICAL SKILL AREA D – Assurance: Audit, Investigation, Compliance and Testing	
D1 – Internal and Statutory Audit	
D2 – Compliance Monitoring and Controls Testing	
D3 – Security Evaluation and Functionality Testing	
D4 – Penetration Testing and Conducting Simulated Attack Exercises	



TECHNICAL SKILL AREA E – Operational Security Management	
E1 – Secure Operations Management	
E2 – Secure Operations and Service Delivery	
TECHNICAL SKILL AREA F – Incident Management, Investigation and Digital Forensics	
F1 – Intrusion Detection and Analysis	
F2 – Incident Management, Incident Investigation and Response	
F3 – Forensics	
F4 – Digital Investigation	
TECHNICAL SKILL AREA G – Data Protection, Privacy and Identity Management	
G1 – Data Protection	ESSENTIAL
G2 – Privacy	ESSENTIAL
G3 – Identity and Access Management	
TECHNICAL SKILL AREA H – Business Resilience	
H1 – Business Continuity and Disaster Recovery Planning	
H2 – Business Continuity and Disaster Recovery Management	
H3 – Cyber Resilience	
TECHNICAL SKILL AREA I – Cyber and Information Security Research	
I1 – Research	
I2 – Applied Research	
TECHNICAL SKILL AREA J – Human Centric Security	
J1 – Security Behaviour and Engagement (People)	
J2 – Security Culture Management & Continuous Improvement (Process)	
J3 – Secure Enablement and Digital Behaviour (Technology)	



PROFESSIONAL SKILL AREA 1 – Management, Leadership, Business and Communications	
1a – Management, Leadership and Influence	MANDATORY
1b – Business Skills	MANDATORY
1c – Communication and Knowledge Sharing	MANDATORY
PROFESSIONAL SKILL AREA 2 – Contributions to the Cyber and Information Security Profession and Professional Development	
2a – Contributions to the Community	
2b – Contributions to the IS Profession	
2c – Professional Development	MANDATORY



Skills Framework

Version 4 | April 2026



Skills Summary

DEFINITIONS FOR LEVELS

CIISec Skills Framework v4.0 (C) 2026 by Chartered Institute of Information Security is licensed under [CC BY-NC-ND 4.0](#).
To be used in accordance with the CIISec [terms and conditions](#)



Skills Summary – Definitions for Levels 1 to 3

The following definitions should be used for assessment of competencies in the Skill Areas A – J.

LEVEL 1:

(Knowledge) Basic Knowledge

Has acquired and can demonstrate basic knowledge associated with the skill, e.g. through training or self-tuition.

LEVEL 2:

(Knowledge and Understanding) Basic Principles

Understands the skill and its application.

Knowledge

Has acquired and can demonstrate the basic knowledge associated with the skill, for example has attended a training course or completed an academic module in the skill. Understands how the skill should be applied.

Practice

Can explain the principles of the skill and how it should be applied. This might include experience of applying the skill to basic tasks in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises in using the skill, and/or passing a test or examination. Should be aware of recent developments in the skill.

LEVEL 3:

(Apply) Junior Practitioner

Understands the skill and applies it to basic tasks with some supervision.

Knowledge

Has acquired a good understanding of the knowledge associated with the skill and understands how the skill should be applied.

Practice

Has experience of applying the skill to a variety of basic tasks. Can work as an effective member of a team. Contributes ideas in the application of the skill. Demonstrates awareness of recent developments in the skill.

Can explain the skill to potential and current cyber and information security professionals.



Skills Summary – Definitions for Levels 4 to 6

The following definitions should be used for assessment of competencies in the Skill Areas A – J.

LEVEL 4:

(Enable) Practitioner

Understands the skill and applies it to basic tasks with minimal supervision and to complex tasks with some supervision. Normally operates as a member of a team in a project/programme or system environment.

Knowledge

Has acquired a deep understanding of the knowledge associated with the skill. Understands how the skill should be applied.

Practice

Has experience of applying the skill to a variety of tasks, including some complex tasks under supervision. Contributes ideas in the application of the skill. Demonstrates awareness of recent developments in the skill. Contributes ideas for technical development and new areas for application of the skill.

Can explain the skill to potential and current cyber and information security practitioners.

LEVEL 5:

(Advise) Senior Practitioner

Understands the skill and applies it to complex tasks with no supervision. Leads or provides Subject Matter Expertise (SME) to teams in a project/programme or system environment. Operates at a corporate level either operationally and/or strategically.

Knowledge

Has acquired a deep understanding of the knowledge associated with the skill. Understands how the skill should be applied across a number of projects in different client environments and/or within a large corporate organisation.

Practice

Has experience of applying the skill to a variety of complex tasks. Demonstrates significant personal responsibility or autonomy, with little need for escalation. Contributes ideas in the application of the skill. Demonstrates awareness of recent developments in the skill. Contributes ideas for technical development and new areas for application of the skill and contributes to public discussion and debate on the skill. Has effective leadership and management skills.

Has experience of training cyber and information security professionals in the skill at an advanced level or as a university lecturer.

LEVEL 6:

(Initiate, Enable, Ensure) Principal/Lead Practitioner

An authority who leads or provides SME to enable implementation of the skill. Is an acknowledged expert by peers in the skill.

Knowledge

Has acquired a deep understanding of the knowledge associated with the skill. Understands how the skill should be applied across a number of projects in different client environments and/or within a large corporate organisation.

Practice

Has oversight responsibility for overall application of the skill across a range of customers or within a large corporate organisation, often reporting at Board level. Takes a strategic approach. Recognised as an SME within a large organisation. Has experience of applying the skill in circumstances without precedence. Proposes, conducts, and/or leads or provides SME to innovative work to enhance the skill. Is approached to provide keynote presentations or papers on the skill.

Develops and leads or provides SME to programmes of advanced training in the skill. A professor or senior lecturer contributing sessions on the skill at MSc level.



Skills Framework

Version 4 | April 2026



Skills Information

DETAILED INFORMATION OF THE SKILLS INVOLVED



TECHNICAL SKILL AREA A - Cyber and Information Security Governance and Management (Essential Skill A2 and A6)

Skills Group	Principles	Example Skills
A1 – Governance	- directs, oversees, designs, implements or operates within the set of multi-disciplinary structures, policies, procedures, processes and controls implemented to manage cyber and information security at an enterprise level. - supporting an organisation's immediate and future regulatory, legal, risk, environmental and operational requirements and ensuring compliance with those requirements.	Level 1: Can describe the principles of cyber and information security governance. Can list the potential impacts that occur where poor information governance has been observed. Level 2: Can explain the basic principles of cyber and information security governance and how it applies within an organisation. Level 3: Understands local (organisation or project) cyber and information security governance processes. Undertakes information security governance tasks under supervision. Recognises and addresses non-compliance and makes recommendations for change. Level 4: Contributes to the development, revision or implementation of cyber and information security governance processes. Level 5: Leads or provides SME to the development, revision or implementation of cyber and information security governance processes. Level 6: Responsible for the development, revision and implementation of cyber and information security governance processes across a range of clients or within a large corporate organisation.
A2 – Policy and Standards	- directs, develops or maintains organisational cyber and information security policies, standards and processes, using recognised standards (e.g. the ISO/ IEC 27000 family, ISO 17025, the Security Policy Framework) where appropriate. - applies recognised cyber and information security standards and policies within an organisation, programme, project or operation. - applies relevant security classification.	Level 1: Can describe the main policies and standards relevant to the cyber and information security skill area and/or organisation. Level 2: Can explain the principal concepts of the main cyber and information security policies and standards. This might include experience of applying knowledge of cyber and information security policies and standards in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination. Level 3: Develops and maintains local or organisational policies under supervision; applies recognised standards (e.g. ISO/IEC 27001, ISO17025, ISA/IEC 62443) under supervision. Level 4: Incorporates recent advances in cyber and information security into existing policies and standards without supervision; manages teams working on policies and standards, mentoring as appropriate. Level 5: Leads or provides SME to the development of policies and standards within an organisation or across a range of clients; interprets cyber and information security standards to support complex decisions or those which set new precedent. Level 6: Co-ordinates cyber and information security policy and standards development within a major organisation; contributes to the development of international or industry sector policies and standards.

To be used in accordance with the CIISec [terms and conditions](#)



Skills Group	Principles	Example Skills
A3 – Cyber and Information Security Strategy	- directs, develops or maintains plans and processes to manage cyber and information security risks and intelligence appropriately and effectively, whilst complying with legal, statutory, contractual, and business requirements. - keeps appropriate records.	Level 1: Can describe the purpose of cyber and information security strategies and how they can benefit the business.
		Level 2: Can explain the basic principles of cyber and information security strategies and how they apply within an organisation.
		Level 3: Drafts or reviews components of cyber and information security strategy at programme or project level and/or contributes to organisational IS strategy.
		Level 4: Leads or provides SME to teams implementing cyber and information security strategy at programme or project level.
		Level 5: Works under direction, but with minimal supervision on the development of corporate cyber and information security strategy.
		Level 6: Advises directors and senior business managers on cyber and information security strategy. Leads or provides SME to the development of and authorises corporate cyber and information security strategy.
A4 – Innovation and Business Improvement	- recognises potential strategic application of cyber and information security and initiates investigation and development of innovative methods of protecting information assets, to the benefit of organisations and stakeholders and the interface between business and cyber and information security. - exploits opportunities for introducing more effective secure business and operational processes.	Level 1: Can list the potential impacts of poor cyber and information security and the business benefits of cyber and information security
		Level 2: Can explain how good cyber and information security strategies and processes can benefit the business, stakeholders and provide examples.
		Level 3: Applies cyber and information security to achieve business objectives with some supervision. With some supervision, provides cyber and information security advice on the design, implementation, configuration or operation of information systems to balance cyber and information security with business and stakeholder objectives.
		Level 4: Conceives and delivers business improvement through the application of cyber and information security; persuades senior stakeholders to invest in cyber and information security.
		Level 5: Applies deep knowledge of cyber and information security and business activities to identify risk or concern within an organisation. Influences and convinces directors and senior managers of the business benefits of improving and investing in cyber and information security.
		Level 6: Applies deep knowledge of cyber and information security and business activities to identify significant risks within a major organisation at Board level. Influences and convinces directors and/or senior managers of the business benefits of improving and investing in cyber and information security.



Skills Group	Principles	Example Skills
A5 – Behavioural Change	- identifies cyber and information security awareness, training and culture management needs in line with security strategy, business needs and strategic direction, and gains management commitment and resources to support these needs. - manages the development or delivery of cyber and information security awareness and training, behavioural analysis programmes and/or security culture management programmes, applying analysis of human factors as appropriate.	Level 1: Recognises the role of cyber and information security awareness and training and can list the benefits of behavioural analysis and security culture management in maintaining good cyber and information security.
		Level 2: Can explain the concepts of cyber and information security awareness and security culture management and give examples of good practice.
		Level 3: Materially contributes to improving cyber and information security awareness by developing and delivering training sessions or as a member of a team undertaking behavioural analysis or delivering a culture management programme.
		Level 4: Designs, develops and presents cyber and information security training courses as part of a training and awareness programme. Identifies gaps in organisational cyber and information security awareness and proposes solutions. Undertakes behavioural analysis projects; develops cultural management programmes.
		Level 5: Leads or provides SME to cyber and information security training and awareness programmes and/or behavioural management programmes.
		Level 6: Drives cultural change by persuading directors and/or senior management of the benefits of behavioural management. Oversees the development and delivery of such programmes.
A6 – Legal and Regulatory Environment and Compliance	- understands the legal and regulatory environment within which the business operates. - ensures that cyber and information security governance arrangements are appropriate. - ensures that the organisation complies with legal and regulatory requirements.	Level 1: Can describe the major legislative and regulatory instruments relevant to cyber and information security (e.g. Data Protection Act, General Data Protection Regulation (GDPR), privacy, healthcare, ISO/IEC 27000 family, and legislation and regulation relevant to a member's area of work (e.g. ISO 17025, Forensic Science Regulator codes, Nuclear Industries Security Regulations (NISR), UK Cyber Assessment Framework, HMG SPF, PCI DSS etc).
		Level 2: Can explain the principal requirements of major legislation and regulations relevant to cyber and information security, and those legal and regulatory instruments relevant to own work.
		Level 3: Understands legislation and regulation applicable to own work, i.e. within own or client organisations. Undertakes updates of cyber and information security policies and standards to comply with legislation and regulation under supervision.
		Level 4: Recognises and reports non-compliances with applicable legislation and regulation. Updates cyber and information security policies and standards to comply with legislation and regulation with minimal supervision.
		Level 5: Analyses changes in legislation or regulation and assesses impact on their own or client organisation. Provides advice on the implications of legislation and regulation on the business, seeking legal advice where necessary.
		Level 6: Identifies the need to change processes or working practices to comply with legislation and regulation and persuades senior management to support and resource the necessary changes.

To be used in accordance with the CIISec [terms and conditions](#)



Skills Group	Principles	Example Skills
A7 – Third Party Management	- identifies and advises on the technical, physical, personnel and procedural risks associated with third party relationships, including systems development and maintenance, contracts, end of service, outsourced service providers and business partners and sub-contracting. - assesses the level of confidence that third party cyber and information security capabilities/services operate as defined.	Level 1: Recognises the need for organisations to manage the cyber and information security of third parties and can describe the impacts of failure to do so. Level 2: Can explain the main security issues associated with third party relationships and how these can be managed effectively. Level 3: Contributes to developing or maintaining processes to assure compliance by third parties to the contracting authority's cyber and information security policies and standards, e.g. by specifying requirements or monitoring compliance, usually as a member of a team. Level 4: Undertakes without close supervision the production of cyber and information security requirements for third parties and/or reviews compliance claims and certifications or conducts compliance reviews. Level 5: Advises senior management and/or contracting authorities on the cyber and information security requirements for third party management. Leads or provides SME to the production of cyber and information security requirements for third parties and/or compliance assurance processes. Level 6: Leads or provides SME to complex negotiations with third parties on behalf of the contracting authority, assuring that the contracting authority's cyber and information security requirements can and will be met.

**TECHNICAL SKILL AREA B - Threat Assessment, Information Risk Management, Intelligence and Data Analysis (Essential Skill B2)**

Skills Group	Principles	Example Skills
B1 – Threat Intelligence, Assessment and Threat Modelling	- assesses, interprets and validates information from multiple sources (including open source) on current and potential cyber and information security threats to the business, analysing trends and highlighting cyber and information security issues relevant to the organisation, including security analytics for big data. - processes, collates exploits data, considering its relevance and reliability to develop and maintain 'situational awareness'. - conducting threat led assessments in context to the business and that of any third party supplier. Recognises specific threats from organised crime, activists and state actors. - understanding third party threats and risks using an holistic approach to threats and risks faced; predicts and prioritises threats to an organisation and their methods of attack. - analyses the significance and implication of processed intelligence to identify significant trends, potential threat agents and their capabilities. - predicts and prioritises threats to an organisation and their methods of attack. Uses human factor analysis in the assessment of threats. - uses threat intelligence to develop attack trees. Prepares and disseminates intelligence reports providing threat indicators and warnings. - conducts or inputs to dynamic threat assessments.	Level 1: Can describe the principles of threat intelligence, modelling and assessment.
		Level 2: Can explain the principles of threat intelligence, modelling and assessment. This might include experience of applying threat intelligence, modelling and assessment principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination.
		Level 3: Undertakes/assesses routine threat intelligence/modelling tasks or threat assessments under supervision. Appropriate and relevant certifications include CREST Registered Threat Intelligence Analyst, SANS GIAC Cyber Threat Intelligence.
		Level 4: Undertakes routine threat intelligence/modelling tasks or threat assessments without close supervision. Undertakes and reports on complex threat intelligence tasks or threat assessments under supervision. Appropriate and relevant certifications for example CREST Registered Threat Intelligence Analyst.
		Level 5: Undertakes and reports on complex threat intelligence/modelling tasks or threat assessments without supervision. Manages threat intelligence/assessment teams. Appropriate and relevant certifications include CREST Registered Threat Intelligence Manager.
		Level 6: Leads corporate threat intelligence processes, reporting to the Board.



Skills Group	Principles	Example Skills
B2 – Risk Assessment	identifies and assesses information assets; uses this information and relevant threat assessments, business impacts, business benefits and costs to conduct risk assessments and identify and assess potential vulnerabilities (assets can also include employees and customers).	Level 1: Can describe the concepts and principles of risk assessment.
		Level 2: Can explain the principles of risk assessment. This might include experience of applying risk assessment principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination.
		Level 3: Undertakes basic risk assessments with some supervision.
		Level 4: Undertakes complex risk assessments with supervision, either as an individual or a member of a team.
		Level 5: Leads complex risk assessments, interfacing routinely with senior management.
		Level 6: A recognised authority on risk assessment within a major organisation or across a range of clients or within an industry sector.
B3 – Information Risk Management	develops cyber and information security risk management strategies and controls, considering business needs and risk assessments, and balancing technical, physical, procedural and personnel controls.	Level 1: Can describe the concepts and principles of cyber and information security risk management.
		Level 2: Can explain the principles of information risk management. This might include experience of applying risk management principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination.
		Level 3: Develops basic information risk management plans with some supervision.
		Level 4: Develops complex and innovative information risk management plans under supervision.
		Level 5: Develops complex and innovative information risk management plans either as an individual or leading a team.
		Level 6: A recognised authority on information risk management within a major organisation or across a range of clients.



Skills Group	Principles	Example Skills
B4 – Cyber Digital Intelligence	• advises on and coordinates support to others in cyber digital case initiation. • creates, sets and practices the correct procedures for the handling and dissemination of cyber digital intelligence, ensuring that it meets the national intelligence model or other recognised approaches. • can utilise appropriate intelligence gathering, assessment, understanding of various data collection capabilities e.g. radio frequency geolocation methods and capabilities and use presentation tools. • presents evidence as appropriate, acting as an expert witness if necessary. • able to identify where gaps in intelligence exist and mitigate appropriately. • recognises the importance - with regard to the protection - of sensitive and or covert sources (including human). • understands the risk and impact of cognitive bias in interpreting intelligence outcomes.	Level 1: Can describe the basic principles of digital intelligence and recognises the capability of digital intelligence to support investigations.
		Level 2: Can explain the basic principles of digital intelligence and associated investigations using such techniques, including the principles and processes surrounding securing and analysing evidence, gathering data analytics such as geolocation. This might include experience of applying these principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises and/or passing a test or examination.
		Level 3: Contributes to digital intelligence activities with some supervision.
		Level 4: Undertakes basic digital intelligence tasks (e.g. searching of open source) without supervision. Has some experience of more complex tasks (e.g. using specialist tools to search, recover, preserve and analyse data) under supervision. Able to utilise such skills to conduct an investigation to legal standards.
		Level 5: Manages teams or provides SME to teams conducting digital intelligence using forensic techniques, RF surveys and tools. Experienced in using multiple digital search and forensic tools and techniques and capabilities to assist in an investigation.
		Level 6: Responsible for digital investigations within a large organisation or across multiple customers. Leads challenging digital intelligence requirements. Has in-depth understanding of the relevant laws, and guidance.
B5 – Data Analysis	• contributes to analysis, assessing and acting upon information identified through intelligence, system and or log analysis. • understanding the customer requirement and sector specific issues. • use of creative and critical thinking skills. • identifying where analysis can and cannot assist in decision making. • remains focussed on the outcome of the data analysis through skilful determination of the results and not jump to conclusions or be directed to prove or disprove interpretations.	Level 1: Can describe the concepts and principles of data analysis.
		Level 2: Can explain the concept of data analysis, how it relates to business needs and how it can be used to reduce information risk.
		Level 3: Applies data analysis principles with some supervision.
		Level 4: Undertakes data analysis task. Able to differentiate between relevant and irrelevant data relating to the task.
		Level 5: Manages teams or provides SME to teams conducting data analysis techniques and tools. Experienced in using multiple digital search and analytic tools and techniques and capabilities to assist in informing the business on risks and opportunities.
		Level 6: Responsible for data analysis within a large organisation or across multiple customers. Leads challenging data analysis requirements. Has in depth understanding of the relevant laws, and guidance relating to data analysis.



TECHNICAL SKILL AREA C - Implementing Secure Systems

Skills Group	Principles	Example Skills
C1 – Enterprise Security Architecture	- working with enterprise architects, takes customer security requirements and assists in the development of an enterprise cyber and information security architecture including operation technology security (OT) – industrial control systems (e.g. SCADA). - interprets relevant security policies and threat/ risk profiles into secure architectural solutions that mitigate the risks and conform to legislation and regulations and relate to business needs. - applies common architectural frameworks (e.g. TOGAF, SABSA ISA/IEC 62443). - presents security architecture solutions as a view within broader IT architectures. - maintains awareness of the security advantages and vulnerabilities of common products and technologies. - designs robust and fault-tolerant security mechanisms and components appropriate to the perceived risks. - develops and implements appropriate methodologies, templates, patterns and frameworks.	Level 1: Can describe the concept of an enterprise cyber and information security architecture and/or industrial control systems and how it/they can be used to reduce information risk. Level 2: Can explain the concept of an enterprise cyber and information security architecture and/or industrial control systems, how it/they relates to business needs and how it can be used to reduce information risk. This might include experience of applying these concepts in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination. Appropriate and relevant certifications include BCS Practitioner Certificate in Information Assurance Architecture, ISC2 Information Systems Security Architecture Professional (ISSAP). Level 3: Applies enterprise information security architectural principles with some supervision. Recognises whether designs are compliant with key features in the organisation's enterprise cyber and information security architecture and/or industrial control systems. Level 4: Applies enterprise information security architectural and/or industrial control systems principles with little supervision. Has a broad understanding of security vulnerabilities and the techniques for applying effective controls. Level 5: Applies enterprise cyber and information security architectural and/or industrial control systems principles in new and complex situations. Recommends appropriate tools and how to apply those tools to achieve the required enterprise cyber and information security architecture. Supervises less experienced practitioners. Level 6: Leads on enterprise cyber and information security architecture and/or industrial control systems at corporate level, reporting to the Board. Develops new enterprise cyber and information security architecture approaches to meet new business and technology requirements.



Skills Group	Principles	Example Skills
C2 – Technical Security Architecture	- contributes to the development of computer, network and storage security architecture, incorporating hosting, infrastructure applications, industrial control systems and cloud based solutions as covered by the role of chief security architect. - interprets relevant security policies and threat/risk profiles into secure architectural solutions that mitigate the risks, conform to legislation and regulations and relate to business needs. - presents security architecture solutions as a view within broader IT architectures. - applies security architecture principles to networks, IT systems, Operational Technology (OT) and other control systems (e.g. SCADA, ICS), infrastructures and products. - devises standard solutions that address requirements delivering specific security functionality whether for a business solution or for a product. - maintains awareness of the security advantages and vulnerabilities of common products and technologies. - understands the technology and how criminals can make use of these vulnerabilities and where advantages may assist in investigations. - designs robust and fault-tolerant security mechanisms and components appropriate to the perceived risks. - uses appropriate methodologies and frameworks. - understands wider technology e.g. cloud based vehicle telematics, building management and internet of things. - uses knowledge of threats and attack paths to architect and design in system resilience so as to be able to slow or resist attack.	Level 1: Can describe the principles of a technical security architecture and/or industrial control systems and how these can be used to reduce information risk. Level 2: Can explain the principles of a computer system, network or storage security architecture and/or Industrial Control Systems and how these can be used to reduce information risk. This might include experience of applying these concepts in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination. Appropriate and relevant certifications include CREST Registered Technical Security Architect (CRTSA), BCS Practitioner Certificate in Information Assurance Architecture, ISC2 Information Systems Security Architecture Professional (ISSAP). Level 3: Applies architectural principles and/or industrial control systems principles to security design with some supervision. Recognises whether designs are compliant with key features in the organisation's enterprise cyber and information security architecture. Uses common design patterns to reduce information risk. Level 4: Applies security architectural principles and/or industrial control systems principles with little supervision. Has a broad understanding of security vulnerabilities and the techniques for applying effective controls. Level 5: Has a broad understanding of security vulnerabilities and the techniques for applying effective controls. Applies security architectural principles to new and complex networks, infrastructure and industrial control systems principles and is able to bring structure to disparate systems. Supervises less experienced practitioners. Influences senior managers and IT/OT engineers to adopt secure architectural principles in new systems. Level 6: Is responsible for developing technical security architectures and/or industrial control systems for application across a range of customers or within a large organisation. Develops new technical security architecture approaches to meet new business and technology requirements. Influences senior managers to adopt secure architectural principles to reduce information risk and to migrate legacy and existing systems into a security architectural framework supporting resilience. Leads or provides SME to internal workshops to develop security architecture.

To be used in accordance with the CIISec [terms and conditions](#)



Skills Group	Principles	Example Skills
C3 – Secure Development	- implements and updates secure systems, products and components using an appropriate methodology. - defines and/or implements secure development standards and practices including, where relevant, formal methods. - selects and/or implements appropriate test strategies. - defines and/or implements appropriate secure change and fault management processes. - verifies that a developed component, product or system meets its security criteria (requirements and/or policy, standards and procedures). - specifies and/or implements processes that maintain the required level of security of a component, product, or system through its lifecycle. - manages a system or component through a formal security assessment.	Level 1: Recognises the benefits of addressing security during system development and can list some of the tools, products and practices that contribute to secure development.
		Level 2: Can explain the benefits of addressing security during system development. Can describe some of the tools, products and practices that contribute to secure development.
		Level 3: Contributes to the development of secure systems with some supervision. Proposes security requirements for new systems or changes to existing systems with some supervision.
		Level 4: Contributes to the development of secure systems without close supervision. Proposes security requirements for new systems or changes to existing systems without close supervision.
		Level 5: Applies secure development practices to complex security requirements without supervision. Leads or provides SME to secure development teams.
		Level 6: Applies and improves secure development practices across multiple, projects systems and products. Develops new techniques and/or tools that significantly improve secure development capabilities. Leads or provides SME to secure development within an organisation.



TECHNICAL SKILL AREA D – Assurance: Audit, Investigation, Compliance and Testing

Skills Group	Principles	Example Skills
D1 – Internal and Statutory Audit	• verifies that information systems, investigations and processes meet the security criteria (requirements or policy, standards and procedures). • able to reconstruct timelines for investigative and evidential purposes. • assesses the business benefits of security controls. • maintains contemporaneous records.	Level 1: Can describe the requirements for, and basic principles involved in conducting security audits of information systems, investigations and processes.
		Level 2: Can explain the main principles and processes involved in conducting an audit. This might include experience of applying these principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination.
		Level 3: Contributes to security audits under supervision.
		Level 4: Conducts security audits under supervision as part of a team.
		Level 5: Leads or provides SME to teams of auditors conducting internal or external audits. Produces and agrees plans for each audit. Agrees solutions and actions with management.
		Level 6: Responsible for the delivery of security audits for a large organisation or across a range of customer organisations. Develops the corporate audit plan and approach and oversees delivery against the plan. Leads audits instigated by directors, Ministers or regulatory bodies to identify root causes of security incidents of widespread interest.
D2 – Compliance Monitoring and Controls Testing	• defines and implements processes to verify on-going conformance to security and/or legal and regulatory requirements. • carries out security compliance checks in accordance with an appropriate methodology. • this skill group covers compliance checks and tests against technical, physical, procedural and personnel controls.	Level 1: Can describe the benefits of compliance monitoring and list the common compliance monitoring standards, e.g. ISO/IEC 27001, PCI DSS, ISO 17025.
		Level 2: Can explain the main principles and processes involved in conducting a compliance monitoring exercise. This might include experience of applying these principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises and/or passing a test or examination.
		Level 3: Assists with compliance monitoring and/or controls testing exercises under supervision.
		Level 4: Is an experienced member of a team conducting compliance monitoring and/or controls testing.
		Level 5: Leads or provides SME to teams conducting compliance monitoring and/or controls testing, reporting findings to middle management; escalates issues as appropriate.
		Level 6: Is a recognised authority on compliance monitoring and controls testing with overall responsibility for compliance monitoring within a large organisation or across a range of customers. Reports significant non-compliance issues to senior management.

To be used in accordance with the CIISec [terms and conditions](#)



Skills Group	Principles	Example Skills
D3 – Security Evaluation and Functionality Testing	• contributes to the security evaluation or testing of software. • evaluates security software by analysing the design documentation and code to identify potential vulnerabilities and testing to ascertain whether these are exploitable. • tests the security functionality of systems or applications for correctness in line with security policies, standards and procedures and advises on corrective measures. • applies recognised evaluation/testing methodologies, tools and techniques, developing new ones where appropriate. • assesses the robustness of a system, product or technology. • applies commonly accepted governance practices and standards when testing in an operational environment.	Level 1: Can describe the principal concepts of security evaluation and functional testing to support cyber and information security. Recognises that security testing cannot guarantee security.
		Level 2: Can explain the principal concepts of security evaluation or functional testing and how these are applied in practice. This might include experience of applying these concepts in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination.
		Level 3: Develops test schedules and/or implements them under supervision. Develops product or system test plans under supervision. Drafts security requirements under supervision.
		Level 4: Designs effective test programmes for systems, products applications or processes and is trusted to implement them.
		Level 5: Leads or provides SME to security evaluation or functionality testing teams.
		Level 6: Acts as an expert adviser to customers on security testing policy within a large organisation or across several clients.



Skills Group	Principles	Example Skills
D4 – Penetration Testing and Conducting Simulated Attack Exercises	• contributes to the scoping and conduct of vulnerability assessments and tests for public domain vulnerabilities and assessment of the potential for exploitation, where appropriate by conducting exploits. • reports potential issues and mitigation options. • contributes to the review and interpretation of reports. co-ordinates and manages remediation action plan (RAP) responses. • this skill group covers, but is not limited to, penetration testing against networks and infrastructures, web applications, mobile devices and control systems, (testing can also include physical and/or procedural defences). • this skill group also covers contributing to the conduct of testing and simulated attack exercises based on scenarios derived from threat intelligence, potential threat agents and their capabilities. • predicts and prioritises threats to an organisation and their methods of attack. • uses human factor analysis in the assessment of threats. • uses threat intelligence to develop attack trees. • prepares and disseminates intelligence reports providing threat indicators and warnings.	Level 1: Can describe the principles of penetration testing and list the common types of penetration test – e.g. infrastructure, web applications, etc. Recognises the difference between a vulnerability assessment and a penetration test. Can describe the differences between red team, blue team and purple team simulated attack exercises.
		Level 2: Can explain the principles of penetration testing, the main components of an infrastructure penetration test and the high level processes involved. This might include recognised training in infrastructure penetration testing involving practical exercises in using these skills. Can explain the principles of simulated attack exercises based on scenarios derived from threat intelligence and the high level processes involved. Appropriate and relevant certifications include Certified Ethical Hacker (CEH) or equivalent.
		Level 3: Uses commercial tools to conduct vulnerability assessments and basic penetration testing under supervision. Assists with scoping tests or attack exercises and interpreting results. Appropriate and relevant certifications include CREST, The Cyber Scheme, Practitioner Security Analyst, EC-Council Certified Security Analyst (ECSA) or equivalents.
		Level 4: Uses commercial and bespoke tools to conduct basic penetration testing without supervision and complex infrastructure penetration testing under supervision. Undertakes attack exercises under direction as part of a team. Scopes relatively simple tests and interprets results with little supervision. Appropriate and relevant certifications include CHECK Team Member awarded through CREST and The Cyber Scheme.
		Level 5: Uses commercial and bespoke tools to conduct complex penetration testing without close supervision and/or leads or provides SME to teams undertaking complex penetration tests. Undertakes penetration exploits as part of a simulated attack exercise under direction. Appropriate and relevant certifications include CHECK Team Leader awarded through CREST and The Cyber Scheme.
		Level 6: Responsible for the effective delivery of complex and challenging penetration testing services to a range of customers. Appropriate and relevant certifications include CHECK Team Leader awarded through CREST and The Cyber Scheme. Responsible for the design and delivery of attack exercises based on threat intelligence to a range of customers. Appropriate and relevant certifications include CREST and The Cyber Scheme Certified Simulated Attack Specialist (CC SAS), CREST and The Cyber Scheme Certified Simulated Attack Manager (CC SAM). If required, able to design and direct testing approaches for OT environments that do not jeopardise systems integrity or safety.



TECHNICAL SKILL AREA E - Operational Security Management

Skills Group	Principles	Example Skills
E1 – Secure Operations Management	- establishes processes for maintaining the security of information throughout its existence including establishing and maintaining security operating procedures in accordance with security policies, standards and procedures. - co-ordinates penetration and other testing on information processes. - assesses and responds to new technical, physical, personnel or procedural vulnerabilities. - engages with the change management process to ensure that vulnerabilities are mitigated. - manages the implementation of cyber and information security programmes, and co-ordinates security activities across the organisation.	Level 1: Recognises the need for secure management of information systems and can list some of the types of incidents which could occur if this is not done. Level 2: Understands and can explain the main processes for managing the security of information systems. This might include experience of applying these concepts in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises and/or passing a test or examination. Level 3: Develops or operates security management procedures and processes with some supervision. Monitors the application of security operating procedures with some supervision. Level 4: Develops and/or operates security management procedures and processes without close supervision. Monitors the application of security operating procedures without close supervision. Level 5: Manages and/or provides SME to security management teams. Identifies and implements new management controls to reflect changes in factors such as threat levels and legislation. Level 6: Responsible to the Board for secure operations and service delivery for a major organisation.
E2 – Secure Operations and Service Delivery	- securely configures and maintains information, control and communications equipment in accordance with relevant security policies, standards and guidelines - this includes the configuration of cyber and information security devices (e.g. firewalls) and protective monitoring tools (e.g. SIEM). - implements security policy (e.g. patching policies), security operating procedures in respect of system and/or network management and access control - both technical and physical. - undertakes routine technical vulnerability assessments. - maintains security records and documentation in accordance with security operating procedures. - administers logical and physical user access rights and monitors processes for violations of relevant security policies (e.g. acceptable use, security, etc.).	Level 1: Recognises the need for information systems and services to be operated securely and can list some of the main policies and practices involved in achieving this. Level 2: Can explain the main principles of secure configuration of security components and devices, including firewalls, and protective monitoring tools (e.g. SIEM). This might include experience of applying these principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination. Level 3: Applies routine security procedures such as patching, managing access rights, malware protection or vulnerability testing under direction/supervision. Level 4: Develops security operating procedures for use across multiple information systems or maintains compliance with them. Level 5: Leads or provides SME to teams managing secure operations and service delivery within an organisation. Identifies the need for and implements new security operating procedures and practices to meet changing requirements. Level 6: Is responsible to the Board for secure operations and service delivery for a major organisation.

To be used in accordance with the CIISec [terms and conditions](#)



TECHNICAL SKILL AREA F - Incident Management, Investigation and Digital Forensics

Skills Group	Principles	Example Skills
F1 – Intrusion Detection and Analysis	- monitors network and system activity to identify potential intrusion or other anomalous behaviour. - analyses the information and initiates an appropriate response, escalating as necessary. - uses security analytics, including the outputs from intelligence analysis, predictive research and root cause analysis in order to search for and detect potential breaches or identify recognised indicators and warnings. - monitors, collates and filters external vulnerability reports for organisational relevance, ensuring that relevant vulnerabilities are rectified through formal change processes. - ensures that disclosure processes are put in place to restrict the knowledge of new vulnerabilities until appropriate remediation or mitigation is available. - produces warning material in a manner that is both timely and intelligible to the target audience(s). - understands and uses outputs from intrusion detection and analysis to assist in investigations.	Level 1: Recognises the need for intrusion detection and analysis to maintain cyber and information security and can describe the difference between intrusion prevention and intrusion detection.
		Level 2: Can explain the basic principles involved in monitoring network and system activity for anomalous behaviour and how the results can be used. This might include experience of applying these principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises, and/or passing a test or examination.
		Level 3: Operates as a member of an intrusion and analysis team under supervision. Appropriate and relevant certifications include CREST and The Cyber Scheme.
		Level 4: Operates as a member of an intrusion and analysis team without close supervision. Appropriate and relevant certifications include CREST and The Cyber Scheme.
		Level 5: Manages or provides SME to intrusion and analysis teams. Responsible for taking decisions on appropriate response, escalating as necessary. Liaises with relevant threat intelligence units. Appropriate and relevant certifications include CREST and The Cyber Scheme.
		Level 6: Leads on intrusion and analysis within an organisation. Advises and influences the Board on intrusion and detection issues.



Skills Group	Principles	Example Skills
F2 – Incident Management, Incident Investigation and Response	- engages with the overall organisation incident management process to ensure that cyber and information security incidents are handled appropriately. - defines and implements processes and procedures for detecting and investigating cyber and information security incidents. - identifying what is significant evidence or activity. - establishes and maintains a computer security emergency response team or similar to deal with cyber and information security incidents. - working within the legal constraints imposed by the jurisdictions in which an organisation operates, carries out an investigation into a security incident using all relevant sources of information. - investigates security incidents that have a suspected civil or criminal involvement (investigations may be internal, external and include those conducted by law enforcement). - investigations must be conducted in accordance with relevant legislation and recognised good practice. - presents evidence as appropriate, acting as an expert witness if necessary. - assesses the need for forensic activity and co-ordinates the activities of internal or third party specialist forensic personnel within the overall response activities, engaging with the relevant organisational processes to ensure that forensic services are deployed appropriately. - ensures first response actions are applied. - provides a full cyber and information security investigation capability where third parties, managed service providers are involved. - co-ordinates the response to a cyber and information security incident.	Level 1: Recognises the benefits of managing cyber and information security incidents and can describe the basic principles of incident management, investigation and response.
		Level 2: Can explain the basic principles of incident management, investigation and response. Can describe how incident management can operate effectively, benefiting the organisation. Understands the need to preserve evidence to support any investigation and can explain the basic principles involved.
		Level 3: Contributes to cyber and information security incident management policy and/or incident management and investigation procedures under some supervision. Contributes to cyber and information security incident management and/or investigation processes. Undertakes information security investigation tasks under supervision.
		Level 4: Contributes to cyber and information security incident policy and/or incident management and investigation procedures without supervision. Contributes to cyber and information security incident management and/or investigation processes. Undertakes some cyber and information security investigation tasks without supervision. May take some responsibility for managing and investigating cyber and information security incidents.
		Level 5: Takes full responsibility for managing and investigating cyber and information security incidents. Ensures that the cyber and information security incident management processes are aligned with generic incident management and business continuity processes. Advises on corporate response to an incident. Appropriate and relevant certifications include CREST and The Cyber Scheme.
		Level 6: Is experienced in handling major cyber and information security incidents, recognised as the authority across the organisation and represents them for media comment. Is responsible for deciding on and organising the appropriate corporate response to a cyber and information security incident.

To be used in accordance with the CII Sec [terms and conditions](#)



Skills Group	Principles	Example Skills
F3 – Forensics	- secures the scene, captures and preserves evidence in accordance with legal and safe handling, transportation and storage guidelines and in the most effective manner to minimise disruption to the business and maintaining evidential weight, using specialist equipment as appropriate. - is able to identify and manage live volatile data. - analyses and evaluates the evidence to identify breaches of policy, regulation or law, including the presence of malware. - presents evidence as appropriate, acting as an expert witness if necessary. - sources of evidence can include networks, devices, storage etc.	Level 1: Can describe the basic principles of digital forensics and recognises the capability of forensics to support investigations.
		Level 2: Can explain the basic principles of digital forensics, including the principles and processes surrounding securing and analysing evidence. This might include experience of applying these principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises and/or passing a test or examination.
		Level 3: Contributes to forensic activities with some supervision.
		Level 4: Undertakes basic forensic tasks (e.g. first responder) without supervision. Has some experience of more complex tasks (e.g. using specialist tools to recover, preserve and analyse data) under supervision.
		Level 5: Manages or provides SME to teams conducting investigations using forensic techniques and tools. Experienced in using multiple forensic tools and techniques.
		Level 6: Responsible for forensic operations within a large organisation or across multiple customers. Leads or provides SME to challenging forensic operations. Has in-depth understanding of the relevant laws.



Skills Group	Principles	Example Skills
F4 – Digital Investigation	- investigates and examines digital evidence in accordance with legal guidelines and in the most effective manner, maintaining evidential weight, using specialist equipment and techniques as appropriate. - demonstrates and applies practices to effectively capture and preserve electronic evidence. - analyses the evidence to enable findings to be used to support or negate breaches of policy, regulation or law. - communicates and advises on the significance and types of cyber digital evidence available, making recommendations to investigators. - co-ordinates and communicates the processes to drive first response actions in investigations involving cyber digital related evidence. - advises on the creation, management, maintenance and/or quality assurance of cyber digital investigation plans and case files. - produces cyber digital investigation reports and/or case files to the required standard for presentation at criminal, civil or disciplinary proceedings. - demonstrates the ability to effectively conduct, co-ordinate and provide specialist advice on cyber digital investigations e.g. advice on parameters for radio frequency geolocation surveys. - advises on and co-ordinates support to others in cyber digital case initiation. - presents evidence as appropriate, acting as an expert witness if necessary.	Level 1: Can describe the basic principles of digital investigation and recognises the capability of digital forensics to support investigations.
		Level 2: Can explain the basic principles of digital investigations and associated investigations using such techniques, including the principles and processes surrounding securing and analysing evidence. This might include experience of applying these principles in a training or academic environment, for example through participation in syndicate exercises, undertaking practical exercises and/or passing a test or examination
		Level 3: Contributes to digital investigation activities with some supervision.
		Level 4: Undertakes basic digital investigation tasks (e.g. first responder) without supervision. Has some experience of more complex tasks (e.g. using specialist tools to recover, preserve and analyse data) under supervision. Able to utilise such skills to conduct an investigation to legal standards.
		Level 5: Manages or provides SME to teams conducting digital investigations using forensic techniques and tools. Experienced in using multiple forensic tools and techniques and capabilities to assist in an investigation.
		Level 6: Responsible for digital investigations within a large organisation or across multiple customers. Leads or provides SME to challenging digital investigations. Has in-depth understanding of the relevant laws, and guidance.



TECHNICAL SKILL AREA G - Data Protection, Privacy and Identity Management (Essential Skill G1 and G2)

Skills Group	Principles	Example Skills
G1 – Data Protection	directs, oversees, designs, implements, contributes to, or operates within the set of multi-disciplinary structures, policies, procedures, processes and controls to manage the protection of personal data at an enterprise level, supporting an organisation's immediate and future regulatory, legal, risk, environmental and operational requirements, and ensuring compliance with those requirements. (e.g. data protection and freedom of information legislation).	Level 1: Can describe the principal legal and regulatory instruments relating to the protection of personal data. Can list the principal criteria within those instruments. Can list the penalties relating to non-compliance.
		Level 2: Can explain how the principal legal and regulatory instruments relating to the protection of personal data apply within an organisation. Can describe the corporate impact and recovery activity required in the case of non-compliance.
		Level 3: Understands local (organisation or project) policies and processes relating to the protection of personal data. Undertakes personal data protection tasks under supervision. Recognises and addresses non-compliance and makes recommendations for change.
		Level 4: Contributes to the development, revision, implementation or monitoring of personal data protection policies and processes within an organisation. Undertakes routine personal data protection tasks with minimal supervision.
		Level 5: Leads or provides SME to the development, revision, implementation or monitoring of personal data protection policies and processes across a range of clients or within an organisation. Undertakes complex personal data protection tasks with minimal supervision.
		Level 6: Responsible for the development, revision, implementation and monitoring of personal data protection policies and processes across a range of clients or within a large corporate organisation.



Skills Group	Principles	Example Skills
G2 – Privacy	- directs, oversees, designs, implements, contributes to, or operates within the set of multi-disciplinary structures, policies, procedures, processes and controls to ensure that privacy and human rights legislation and regulations are adhered to. - within a corporate organisation, this applies to employees, contractors, customers and any individual for whom personal information is held.	Level 1: Can describe the principal legal and regulatory instruments relating to personal privacy and human rights. Can list the principal criteria within those instruments. Can list the penalties relating to non-compliance. Level 2: Can explain how the principal legal and regulatory instruments relating to personal privacy and human rights apply within an organisation. Can describe the corporate impact and recovery activity required in the case of non-compliance. Level 3: Understands local (organisation or project) policies and processes relating to the protection of personal data. Undertakes tasks relating to personal privacy and human rights under supervision. Recognises and addresses non-compliance and makes recommendations for change. Level 4: Contributes to the development, revision, implementation or monitoring of personal privacy policies and processes within an organisation. Undertakes routine tasks relating to personal privacy with minimal supervision. Level 5: Leads or provides SME to the development, revision, implementation or monitoring of personal privacy policies and processes across a range of clients or within an organisation. Undertakes complex tasks relating to personal privacy with minimal supervision. Level 6: Responsible for the development, revision, implementation and monitoring of personal privacy policies and processes across a range of clients or within a large corporate organisation.
G3 – Identity and Access Management	- directs, oversees, designs, implements, contributes to, or operates within identity and access management policies, procedures, processes and controls to ensure that access by individuals to IT and information resources is controlled effectively, operating within legal and regulatory constraints and meeting business requirements. - understands where identity access management (IAM) can assist in incident and other types of investigations.	Level 1: Can describe the basic principles of IAM and relevant legal and regulatory instruments. Level 2: Can explain how the principles of IAM apply within an organisation, referencing the relevant legal and regulatory instruments. Level 3: Understands local (organisation or project) IAM policies and processes and the operation of any IAM systems used. Undertakes tasks relating to IAM under supervision. Recognises and addresses non-compliance and makes recommendations for change. Level 4: Contributes to the development, revision, implementation or monitoring of IAM policies and processes within an organisation. Undertakes routine tasks relating to IAM with minimal supervision, including routine management of IAM systems. Level 5: Leads or provides SME to the development, revision, implementation or monitoring of IAM policies and processes across a range of clients or within an organisation. Undertakes complex tasks relating to IAM with minimal supervision, including the implementation and configuration of IAM systems. Level 6: Responsible for the development, revision, implementation and monitoring of IAM policies and processes across a range of clients or within a large corporate organisation.



TECHNICAL SKILL AREA H - Business Resilience

Skills Group	Principles	Example Skills
H1 – Business Continuity and Disaster Recovery Planning	contributes to defining the need for, and the development of Business Continuity Management (BCM) and Disaster Recovery (DR) plans, processes or functions.	Level 1: Recognises the importance of BCM/DR plans for cyber and information security and can list some of the potential consequences if these aspects are not properly considered. Level 2: Can explain and give examples of how BCM/DR plans contributes to cyber and information security. Level 3: Assists with the design, development and implementation of business continuity, crisis management and/or DR plans under supervision. Level 4: Assists with the design, development and implementation of business continuity, crisis management and/or DR plans with minimal supervision. Level 5: Leads or provides SME to teams designing, developing and implementing crisis management and/or BCM/DR plans. Level 6: Has overall responsibility for BCM/DR plans within a large organisation, reporting to the Board. An SME who advises on BCM and DR plans at Board level across a range of organisations.
H2 – Business Continuity and Disaster Recovery Management	- contributes to the implementation, operation and maintenance of business continuity and disaster recovery processes or functions. - advises on how to maintain business continuity whilst investigations and evidence gathering take place including preserving and securing of evidence.	Level 1: Recognises the importance of business continuity and DR management for cyber and information security and can list some of the potential consequences if these aspects are not properly considered. Level 2: Can explain and give examples of how business continuity and DR management contributes to cyber and information security. Level 3: Assists with the implementation and execution of business continuity, crisis management and/or DR plans under supervision. Assists with exercises to test business continuity and disaster recovery plans under supervision. Level 4: Assists with the implementation and execution of business continuity, crisis management and/or DR plans with minimal supervision. Assists with exercises to test business continuity and disaster recovery plans with minimal supervision. Including during and post incident management of evidence that may be required for any investigation. Level 5: Leads or provides SME to teams implementing and executing business continuity, crisis management and/or DR plans. Including during and post incident management of evidence that may be required for any investigation. Establishes and manages an emergency operations centre. Leads or provides SME to exercises to test BCM/DR plans and reports outcomes to senior management. Implements changes to address lessons learned. Level 6: Has overall responsibility for business continuity and disaster recovery operations within a large organisation, reporting to the Board.

To be used in accordance with the CIISec [terms and conditions](#)



Skills Group	Principles	Example Skills
H3 – Cyber Resilience	- contributes to the development and implementation processes to anticipate, recognise and defend against changing cyber and information risk environments which threaten business stability. - development and implementation of plans to introduce a holistic culture of cyber and information security across an organisation aimed at identifying and reacting promptly and effectively to incidents. - proactively influence the design, architecture and tuning of systems to increase their resilience to attack.	Level 1: Can describe the principles and benefits of cyber resilience.
		Level 2: Can explain and give examples of how cyber resilience contributes to cyber and information security.
		Level 3: Operates as a member of a cyber resilience team, or assists with cyber resilience activities, working under supervision.
		Level 4: Operates as a member of a cyber resilience team, or assists with cyber resilience activities, working with minimal supervision.
		Level 5: Leads or provides SME to cyber resilience teams or undertakes complex cyber resilience work without supervision.
		Level 6: Responsible for cyber resilience within a major organisation, able to influence design, procurement, deployment and operations goals to enhance cyber resilience.



TECHNICAL SKILL AREA I - Cyber and Information Security Research

Skills Group	Principles	Example Skills
I1 – Research	- conducts original investigation in order to gain knowledge and understanding relating to cyber and information security. - defines research goals and generates original and worthwhile ideas in cyber and information security. - writes or presents papers, either internally or externally, on the results of research. - contributes to the development of the employing organisation's cyber and information security research policy and participates in or supervises the work of cyber and information security research functions. - develops new or improved models or theories of cyber and information security. - develops new cryptographic algorithms. - in the cyber and information security field, uses existing knowledge in experimental development to produce new or substantially improved devices, products and processes or advance understanding of behavioural response to security controls. - develops new methods of obtaining and securing evidence from networks and devices. - awareness of relevant sources and how to access them.	Level 1: Recognises the different types of cyber and information security research within own sector.
		Level 2: Can describe and give examples on how research has improved cyber and information security.
		Level 3: Has contributed to cyber and Information security research activities.
		Level 4: Has been actively involved in cyber and information security research activities with minimal supervision, including developing and reviewing new ideas, obtaining background information and conducting tests.
		Level 5: Has led or provided SME to teams responsible for delivering against cyber and information security research strategies and/or programmes. Supervises and/or mentors research work of less experienced researchers.
		Level 6: Has been responsible for developing or managing cyber and information security research strategies and/or programmes, defining research goals and generating original and worthwhile ideas in a specialised field within cyber and information security. Presents papers at conferences, writes journal papers of publication quality and/or presents reports of an equivalent technical standard to research clients. In cryptography, has developed new cryptographic algorithms.



Skills Group	Principles	Example Skills
I2 – Applied Research	- vulnerability research and discovery, leading to the development of exploits, reverse engineering and researching mitigation bypasses. - cryptographic research leading to the assessment of existing algorithms. - in the cyber and information security field, uses existing knowledge in experimental development to produce new or substantially improved devices, products and processes. - develops practical application of new methods of obtaining and securing evidence from networks and devices.	Level 1: Recognises the value of applied research in cyber and information security.
		Level 2: Understands the principles of applied research in cyber and information security and might have undertaken some directed practical examples in a training environment.
		Level 3: Has conducted some basic applied research under supervision, e.g. leading to the development of simple exploits or an assessment of an existing cryptographic algorithm.
		Level 4: Has conducted some basic applied research without supervision, e.g. leading to the development of simple exploits or a simple assessment of an existing cryptographic algorithm.
		Level 5: Has led or provided SME to teams conducting applied research. For example, has conducted applied research leading to the development of complex exploits or an in-depth assessment of an existing cryptographic algorithm.
		Level 6: Undertakes advanced research into vulnerabilities or cryptography. For example, has produced complex exploits, undertaken effective reverse engineering and/or effectively researched mitigation bypasses.



TECHNICAL SKILL AREA J - Human Centric Security

Skills Group	Principles	Example Skills
J1 – Security Behaviour and Engagement (People)	- communicates security messages credibly and adapts style to audience and context, engaging stakeholders to foster trust and collaboration. - influences secure behaviours through persuasive, evidence-based guidance and practical support. - applies behavioural science to design, implement, and evaluate interventions that embed secure behaviours into culture and routines, using insights to refine outcomes. - demonstrates strategic influence by engaging senior leaders, executives, and regulatory bodies to model and reinforce security culture, providing evidence-based feedback and building constructive relationships. - analyses human-based security tasks and behavioural drivers to identify vulnerabilities, strengthen controls, monitor compliance, and support continuous improvement.	Level 1: Demonstrates basic cyber security awareness and securely follows instructions.
		Level 2: Understands secure behaviours, explains key concepts, and adapts communication with support.
		Level 3: Applies security principles, supports colleagues, and tailors credible messages to address behavioural risks in daily work.
		Level 4: Identifies behavioural risks, guides secure actions, and embeds improvements in team routines.
		Level 5: Leads security culture initiatives, applies behavioural science for improvement, and provides evidence-based feedback to senior leaders.
		Level 6: Shapes security culture, leads strategic initiatives, mentors others, and influences leaders and external standards.



Skills Group	Principles	Example Skills
J2 – Security Culture Management and Continuous Improvement (Process)	- designs and delivers security awareness, culture, and education programmes, including scenario and role-based training. - integrates security into business processes and workflows, applying lessons learnt to drive continuous improvement. - assesses and improves security culture using feedback mechanisms, monitoring, and industry-standard reporting. - adapts messaging and engagement strategies to audience, context, and feedback, reinforcing culture through leadership and peer networks. - ensures alignment with organisational culture, values, compliance, and policies, demonstrating accountability for protecting sensitive information and evaluating security implications of decisions.	Level 1: Demonstrates awareness of security culture principles and follows established processes for protecting information.
		Level 2: Understands the importance of embedding security in business practices and participates in awareness activities with guidance.
		Level 3: Applies security culture concepts in daily work, supports colleagues, and uses feedback to improve engagement and compliance.
		Level 4: Assesses and refines security culture using feedback, adapts messaging for different audiences, and integrates lessons learnt into processes.
		Level 5: Leads initiatives to strengthen security culture, aligns programmes with organisational values, and demonstrates accountability for sensitive information.
		Level 6: Shapes organisational security culture, drives continuous improvement through strategic programmes, and influences policy, standards, and industry best practice.
J3 – Secure Enablement and Digital Behaviour (Technology)	- understands and addresses how technology influences individual and group behaviours, identifying socio-technical barriers to secure practices. - implements and promotes secure use of digital tools, integrating security controls into user workflows. - automates security reminders, nudges, and interventions to reinforce secure behaviour. - monitors and analyses digital behaviour to identify risk patterns, using technology for feedback collection and reporting.	Level 1: Demonstrates awareness of secure technology use and follows simple instructions to use digital tools safely.
		Level 2: Understands how technology can influence behaviour and participates in secure use of digital platforms, with guidance.
		Level 3: Applies security controls in daily workflows, promotes secure practices, and supports colleagues in using digital tools safely.
		Level 4: Monitors digital behaviour to identify risk patterns, automates basic security reminders, and adapts controls based on feedback.
		Level 5: Leads initiatives to integrate security into digital processes, addresses socio-technical barriers, and uses technology to collect and report feedback for continuous improvement.
		Level 6: Shapes organisational digital security culture, develops advanced automated interventions, mentors others, and influences external standards or communities through strategic use of technology.



Professional Skill Area 1 - Management, Leadership, Business and Communications (Mandatory Skills 1a, 1b and 1c)

Skills Group	Principles	Example Skills
1a – Management, Leadership and Influence	- works effectively in teams, either as a member or leader. - encourages and supports others to meet objectives and to develop as cyber and information security professionals. - is a leader on cyber and information security issues, either locally or across an organisation. - provides technical leadership in a professional field, either within an organisation or across an industry sector. - ensures an ethical approach across all activity.	Level 1: Works co-operatively and professionally with others.
		Level 2: Has received recognised training in management and/or leadership.
		Level 3: Is an effective team member. Encourages and supports colleagues to achieve team objectives.
		Level 4: Leads or provides SME to small groups/teams with delegated authority for a limited range of tasks. Provides support and feedback to encourage and develop colleagues.
		Level 5: Creates and leads formal, informal or virtual teams and/or creates collaborative links with related teams. Addresses and resolves conflict within teams. Provides support and feedback to encourage and develop colleagues. Advises and influences managers. Develops others through coaching, mentoring and advising colleagues.
		Level 6: Provides leadership for any professional field within the organisation. Recognised as a professional authority within a large organisation or across a range of clients. Routinely advises and influences senior management within an organisation, usually at Board level.
1b – Business Skills	- understands local or corporate business aims and uses this knowledge to maximise the cost-effectiveness of cyber and information security. - contributes to the development of cost-effective corporate cyber and information security strategy; takes action to achieve greater corporate efficiency in line with strategic aims. - takes reasoned decisions on cyber and information security, based on business imperatives, aims and objectives e.g. customer priorities, regulatory obligations, or infrastructure and/or OT systems engineering requirements. - understands programmes and project processes to ensure engagement is in place at an early stage.	Level 1: Understands local objectives and organisational aims and how own job supports them.
		Level 2: Understands and supports organisational aims and any regulations and laws that govern own organisation. Works in a cost-effective manner.
		Level 3: Understands aims and issues facing own work areas and organisation. Works effectively to meet with organisational policies, procedures, security and legal constraints.
		Level 4: Ensures that colleagues understand how their work contributes to security of the department and organisation.
		Level 5: Takes actions to achieve greater corporate efficiency. Interprets and reinforces the importance of strategic aims to colleagues. Uses strategic aims to prioritise and drive plans to maximum benefit to the organisation. Influences business decisions.
		Level 6: Develops policy, strategy, projects and programmes for the organisation that support strategic plans. Understands how changing external influences and political climates may impact on future strategies. Has a wide network of internal and external senior contacts and draws on their knowledge and influence to support organisational aims. Takes business decisions.

To be used in accordance with the CIISec [terms and conditions](#)



Skills Group	Principles	Example Skills
1c – Communication and Knowledge Sharing	- communicates information clearly and in a manner relevant to the target audience, required standard and or organisational procedure (e.g. report writing, Board presentation, complex evidence summary to a tribunal or Jury). - influences senior management. - shares knowledge on cyber and information security. - negotiates effectively on cyber and information security issues. - portrays an approachable and open attitude to enable good communication. - ability to conduct interviews relevant to the situation (e.g. disciplinary, job application, legal, investigative). - ability to defend a position (e.g. challenge by a board, regulatory body or legal representative on a recommendation or evidence).	Level 1: Understands and interprets instructions effectively. Communicates effectively with colleagues.
		Level 2: Has clear written and verbal communication skills. Shares information and knowledge with others.
		Level 3: Is sensitive and constructive when challenging other's ideas or decisions.
		Level 4: Proactively shares good practice and expertise with colleagues. Contributes effectively to debates and complex discussion demonstrating well-reasoned arguments and conclusions. Adapts communication style to suit audience, developing effective mechanisms to disseminate information to colleagues.
		Level 5: Is a persuasive communicator using logic to win support and change views. Sets a lead in sharing knowledge across the organisation and the wider community. Uses a variety of effective strategies to capture and share information. Addresses and discusses key concerns and ensures key stakeholders are kept informed.
		Level 6: Is persuasive and diplomatic in external negotiation, influencing major programmes, projects or policy outside of the organisation. Uses and develops knowledge sharing strategies to share experience across organisations. Presents effectively and influentially to a range of audiences.

**Professional Skill Area 2 - Contributions to the Information Security Profession and Professional Development (Mandatory Skill 2c)**

Skills Group	Principles	Example Skills
2a – Contributions to the Community	undertakes activity to broaden awareness, prevention and knowledge of cyber and information security issues, including the risks from social media use, in the wider community – e.g. moderating sessions at schools, community centres, etc.	Level 1: Recognises the need to educate the community on cyber and information security issues.
		Level 2: Attends or participates in cyber and information security community activities.
		Level 3: Has contributed to cyber and information security training sessions within the local community.
		Level 4: Has developed and presented cyber and information security training sessions within the local community.
		Level 5: Has developed and led a programme of cyber and information security education.
		Level 6: Has developed and led a programme of cyber and information security education and training outside the local area, e.g. regionally or nationally.
2b – Contributions to the Information Security Profession	- undertakes voluntary roles within industry forums or professional bodies. - presents sessions on cyber and information security, either within the organisation or at conferences.	Level 1: Recognises the value of cyber and information security professional bodies and industry forums.
		Level 2: Can describe the main cyber and information security professional bodies and industry forums.
		Level 3: Is aware of cyber and information security professional bodies and industry forums and meetings and occasionally attends to listen and learn.
		Level 4: Supports cyber and information security professional bodies and industry forums, contributes to the agenda and takes an active part in the meetings. Can demonstrate experience of mentoring and/or providing support to others.
		Level 5: Gives significant amounts of own time to cyber and information security professional bodies and industry forums to improve either body of knowledge or general awareness of the area. As a volunteer, chairs committees, conducts assessments or interviews, or organises or runs special interest groups.
		Level 6: Has significantly influenced changes and improvements within the security community. Has established influential relationships with government and/or industry stakeholders. Has changed the way that people perceive cyber and information security. Is regularly sought for comment or to speak publicly on a variety of cyber and information security topics. Has published articles or papers relating to specific areas of the industry. Has developed methodologies or products that have advanced the knowledge or management of cyber and information security.

To be used in accordance with the CIISec [terms and conditions](#)



Skills Group	Principles	Example Skills
2c – Professional Development	takes appropriate and timely action to develop and maintain personal cyber and information security knowledge and expertise.	Level 1: Recognises the value of Continuing Professional Development (CPD) to the cyber and information security profession. Can list some of the industry training, certification and accreditation bodies.
		Level 2: Has professional or academic accreditations to support areas of expertise.
		Level 3: Has taken steps within the past year to develop or maintain professional knowledge.
		Level 4: Is a member of CII Sec or another professional body. Regularly takes steps to improve and update own skills sets. Keeps up to date with relevant technologies. Maintains level of knowledge for professional certifications, accreditations and/or qualifications gained.
		Level 5: Encourages professional development within the organisation or industry. Develops or mentors others to assist them in their professional development. Runs workshops or lectures on professional development.
		Level 6: Influences industry training, certification or accreditation organisations within the industry sector. Is sought to speak, comment or produce papers on professional development.



Summary of Changes

Summary of Changes from Version 3

- A separation of Technical and Professional Skills
- Reorganisation of lettering of Technical Skills. The former J and K skills are now named as Professional Skills in their own right. This allows for expansion of new Technical Skills in the future e.g., K,L,M etc.
- The introduction of a new Technical Skill Human Centric Security (named J.)
- Addition of the NCSC definition of Operational Technology (OT). OT is defined as technology that interfaces with the physical world and includes Industrial Control Systems (ICS), Supervisory Control and Data Acquisition (SCADA) and Distributed Control Systems (DCS).
- The change of terminology from “Accredited Membership” to “Professional Registration” to reflect that CII Sec maintains a register of its members. The term Accreditation has many interpretations but not as readily recognised when referring to membership of a Chartered body.



CIISec Frameworks

CHARTERED INSTITUTE OF INFORMATION SECURITY (CIISec) FRAMEWORKS

CIISec Capability Development Methodology	The overall approach by which CIISec Frameworks and supporting resources can be deployed to build an effective cyber and information security skills capability for your organisation. Further information can be found on the CIISec website or contact membership@ciisec.org
CIISec Professional Registration Framework	The CIISec Professional Registration Framework has been developed to define the competency requirements for security professionals to gain Associate, Full and Fellow levels of professional registration. Our approach has been used to underpin external schemes run by the NCSC and law enforcement.
CIISec Skills Framework	Sets out a series of security skill areas in which different security-related roles should be able to display competence. Additionally, the Skills Framework defines a series of 'Skills Levels' (ranging from 1-6 and aligned with each skill area) that can be used to understand different levels of competence in each particular skill area. This also provides a common scale to support assessment and benchmarking activity.
CIISec Knowledge Framework	Comprises the body of cyber and information security knowledge that individuals at Skills Levels 1 and 2 should possess. The Knowledge Framework is broad ranging and covers both cyber and information security management techniques and more technical control concepts.
CIISec Roles Framework	Sets out the primary and secondary cyber and information security skills that will typically be required by each of the identified common cyber and information security roles – ranging from Chief Information Security Officer (CISO) to Penetration Tester and Threat / Vulnerability Analysts.

Applying the Frameworks

Our Frameworks are available for current CIISec members to download from the Member Area for personal use, in line with the terms and conditions. Corporate Members may use them across a department or organisation, providing a powerful way to assess and develop individuals and teams.

The CIISec Skills Framework helps turn skills conversations from subjective opinions into measurable progress, aligning HR, learning and development, and security leadership around shared development goals.

CIISec also works with a preferred skills implementation partner, offering expert consultancy and intuitive software to help Corporate Members understand, develop and optimise workforce capabilities. Please contact membership@ciisec.org for an introduction.



Chartered Institute of Information Security

About CIISec

The Chartered Institute of Information Security [CIISec] is the natural home for the cyber professional community. As the first institute in the space to be granted Royal Charter status, CIISec provides a universally accepted focal point for cyber and information security professionals at every career stage; CIISec is committed to raising levels of competence, and developing teams effectively, ensuring today's professionals are equipped with the skills and knowledge to navigate the cyber threats of tomorrow. This is achieved through having programmes that support development, recognition and success.

- Development - CIISec is the place to go for cyber professional development and ethical practice.
- Recognition - CIISec provides an authoritative voice for the cyber industry and recognition of excellence in practice.
- Success - CIISec helps you and your business succeed securely in the digital world.